

Actividad 3: Identificación y Corrección de Security Misconfiguration

Tema: *Configuración segura en servidores y aplicaciones web*

Objetivo: *Detectar configuraciones inseguras en un servidor web y corregirlas*

¿Qué es Security Misconfiguration?

Security Misconfiguration ocurre cuando un servidor, base de datos o aplicación tiene **configuraciones predeterminadas** o **inseguras**, permitiendo ataques como **exposición de archivos sensibles** o **acceso no autorizado**.

Configuraciones inseguras

Comprobar exposición de información sensible

```
curl -I http://localhost
```

Si la respuesta contiene:

```
Server: Apache/2.4.41 (Ubuntu)
X-Powered-By: PHP/7.4.3
```

```
(root@kali)~[/etc/apache2]
# curl -I http://localhost
HTTP/1.1 200 OK
Date: Fri, 28 Feb 2025 15:28:47 GMT
Server: Apache/2.4.63 (Debian) PHP/8.2.27 OpenSSL/3.4.0
Last-Modified: Sat, 30 Nov 2024 12:33:01 GMT
ETag: "29cf-628208420f1c0"
Accept-Ranges: bytes
Content-Length: 10703
Vary: Accept-Encoding
Content-Type: text/html
```

Los atacantes pueden aprovechar vulnerabilidades conocidas en **versiones específicas** de software.

Corregir la configuración del servidor Apache y Php

Las directivas pueden estar en distintos archivos según la distribución y la configuración de Apache. Intentar encontrarlas con:

```
sudo grep -Ri "ServerSignature|ServerTokens" /etc/apache2/
```

En **Kali Linux**, que usa Debian/Ubuntu como base, las directivas **ServerSignature** y **ServerTokens** se configuran en **security.conf** dentro de **/etc/apache2/conf-available/**.

Editar **/etc/apache2/conf-available/security.conf** para **ocultar versión del servidor en Apache**:

```
ServerSignature Off
ServerTokens Prod
```

La directiva **ServerTokens** en Apache controla cuánta información sobre el servidor se incluye en las cabeceras de respuesta HTTP.

Opción	Ejemplo de Respuesta HTTP	Descripción
Full	Server: Apache/2.4.41 (Ubuntu) OpenSSL/1.1.1	Muestra la versión completa de Apache, el sistema operativo y módulos activos. (Muy inseguro)
OS	Server: Apache/2.4.41 (Ubuntu)	Muestra la versión de Apache y el sistema operativo. (Aún inseguro)
Minimal	Server: Apache/2.4.41	Solo muestra la versión de Apache.
Minor	Server: Apache/2.4	Muestra solo la versión mayor y menor de Apache.
Major	Server: Apache/2	Muestra solo la versión mayor de Apache.
Prod	Server: Apache	Solo muestra "Apache", sin detalles de versión ni sistema operativo. (Recomendado por seguridad)

La directiva **ServerSignature** controla si Apache muestra información sobre el servidor en las páginas de error, listados de directorios y otras respuestas generadas automáticamente.

Opción	Efecto
On	Muestra información completa sobre Apache en páginas de error y listados de directorios. <i>(Inseguro)</i>
Off	No muestra ninguna firma del servidor en las páginas de error y directorios. <i>(Recomendado)</i>
Email	Similar a On, pero agrega la dirección de ServerAdmin en los mensajes de error. <i>(No recomendado por seguridad)</i>

Ocultar la versión de PHP (php.ini)

Pasos para deshabilitar la exposición de PHP en Kali Linux / Debian, primero localizamos el archivo de configuración con el siguiente comando:

```
php --ini | grep "Loaded Configuration File"
```

La salida mostrará la ruta, por ejemplo:

```
Loaded Configuration File: /etc/php/8.2/apache2/php.ini
```

Si se tienen varias versiones de PHP, verificar cuál está en uso con:

```
php -v
```

Editar el archivo **php.ini correspondiente**, sustituyendo la versión encontrada en la ruta (8.2 en el caso anterior):

```
sudo nano /etc/php/8.2/apache2/php.ini
```

Buscar la línea:

```
expose_php = On
```

Modificarla a:

```
expose_php = Off
```

Y reiniciar los servicios

```
sudo systemctl restart apache2
```

Además, si se usa PHP-FPM, también reiniciarlo. FPM (FastCGI Process Manager) es una implementación alternativa al PHP FastCGI. FPM es un servidor de aplicaciones PHP que se encarga de interpretar código PHP. Aunque normalmente se utiliza junto a un servidor web (*Apache2 o nginx*):

```
sudo systemctl restart php8.2-fpm
```

```
(root@kali)-[/etc/apache2]
# curl -I http://localhost
HTTP/1.1 200 OK
Date: Fri, 28 Feb 2025 15:31:49 GMT
Server: Apache
Last-Modified: Sat, 30 Nov 2024 12:33:01 GMT
ETag: "29cf-628208420f1c0"
Accept-Ranges: bytes
Content-Length: 10703
Vary: Accept-Encoding
Content-Type: text/html

(root@kali)-[/etc/apache2]
#
```

La respuesta del servidor **ya no debería mostrar** la versión de Apache ni de PHP.

Mitigación y Mejores Prácticas

*** Deshabilitar listados de directorios si no hay un index (*.htaccess* o *apache2.conf* o *000-default.conf*)**

```
Options -Indexes
```

*** Revisar permisos en archivos sensibles**

```
chmod 640 /etc/apache2/apache2.conf
```

*** Desactivar métodos HTTP inseguros como PUT, DELETE, TRACE, OPTIONS**

```
<Directory />
  <LimitExcept GET POST>
    Deny from all
  </LimitExcept>
</Directory>
```

* Configurar cabeceras de seguridad en Apache

```
Header always unset X-Powered-By
Header always set X-Frame-Options "DENY"
Header always set X-XSS-Protection "1; mode=block"
Header always set X-Content-Type-Options "nosniff"
```

- ☐ Header always unset X-Powered-By → Oculta información sobre **PHP**.
- ☐ Header always set X-Frame-Options "DENY" → Previene ataques de **Clickjacking**.
- ☐ Header always set X-XSS-Protection "1; mode=block" → Protege contra ataques **XSS**.
- ☐ Header always set X-Content-Type-Options "nosniff" → Evita ataques **MIME Sniffing**.

Configuración FINAL del archivo *000-default.conf*

```
<VirtualHost *:80>
    ServerAdmin webmaster@localhost
    DocumentRoot /var/www/html

    # Deshabilitar listado de directorios
    <Directory /var/www/html>
        Options -Indexes
    </Directory>

    # Desactivar métodos HTTP inseguros (Solo permite GET y POST)
    <Directory />
        <LimitExcept GET POST>
            Deny from all
        </LimitExcept>
    </Directory>

    # Configurar cabeceras de seguridad
    <IfModule mod_headers.c>
        Header always unset X-Powered-By
        Header always set X-Frame-Options "DENY"
        Header always set X-XSS-Protection "1; mode=block"
        Header always set X-Content-Type-Options "nosniff"
    </IfModule>

    # Otras configuraciones de logs y errores
    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined
</VirtualHost>
```

```
(root@kali)-[/etc/apache2]
# curl -I http://localhost
HTTP/1.1 200 OK
Date: Fri, 28 Feb 2025 15:37:27 GMT
Server: Apache
X-Frame-Options: DENY
X-XSS-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Last-Modified: Sat, 30 Nov 2024 12:33:01 GMT
ETag: "29cf-628208420f1c0"
Accept-Ranges: bytes
Content-Length: 10703
Vary: Accept-Encoding
Content-Type: text/html
```

```
(root@kali)-[/etc/apache2]
#
```